

Relatório de Auditoria de Segurança - TraficcAgent

Data: 13/09/2026

Escopo: código-fonte, frontend estático, configuração Docker/Cloud Build, histórico Git e bundle frontend.

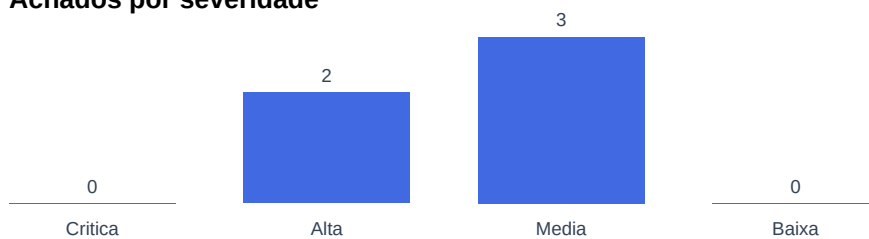
Nota metodológica: as categorias foram mapeadas para a stack detectada: Python sem framework web/ORM, HTML/CSS/JavaScript estático, localStorage, Docker Compose e Cloud Build. Não foram presumidas rotas, RLS ou auth inexistentes.

Resumo executivo

Foram verificados 5 achados acionáveis: 2 altos e 3 médios. Não foi encontrado achado crítico ou baixo. As categorias IDOR e backend de isolamento por rota não se aplicam porque não há handlers HTTP no repositório.

Severidade	Total
Alta	2
Média	3
Crítica	0
Baixa	0

Achados por severidade



Achados por categoria



Pontos fortes e limitações

Pontos fortes verificados:

- Segredos de ambiente estão em .env.example como placeholders vazios; não foram encontradas chaves reais no bundle atual.
- O backend não expõe endpoints HTTP nem queries SQL; portanto não há IDOR HTTP verificável neste snapshot.
- Não há Helm/Terraform nem frontend framework com dangerouslySetInnerHTML; a superfície foi auditada diretamente nos sinks DOM encontrados.

Pontos fracos:

- O MVP não possui fronteira de identidade, autorização ou tenant.
- Dados do negócio ficam no navegador e HTML é montado por concatenação.
- Compose possui credencial de desenvolvimento fixa.

Achados detalhados

Severidade	Arquivo:linha	Descrição
Alta	docker-compose.yml:11-13	Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco). Se o Compose for exposto ou reutilizado fora de uma rede local isolada, a senha é previsível e reutilizável; não há validação que rejeite esses valores em produção.
Média	dist/index.html:12-15	O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape. Um valor como nome, nicho, produto, site ou status contendo HTML pode executar script no mesmo contexto quando renderizado. A exploração exige escrita no localStorage ou entrada pelo próprio fluxo local.
Média	dist/operacao.html:21,23	Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização. Uma decisão contendo marcação HTML pode executar script ao reabrir/renderizar a operação; a exploração é limitada ao contexto local da aplicação.
Alta	traffccagent/__main__.py:1-17; dist/index.html:1-15	Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático. Se publicado como sistema multiusuário, qualquer pessoa com acesso à URL poderá operar o painel; os papéis visuais não formam uma barreira no servidor.
Média	dist/index.html:12-15; dist/operacao.html:19-23	Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage. Usuários do mesmo perfil/origem podem ler, alterar, duplicar ou arquivar dados uns dos outros. Isso é uma lacuna de arquitetura do MVP, não um IDOR HTTP.

Recomendações priorizadas

P1 Definir autenticação, autorização server-side e modelo de tenant antes de transformar o mockup em produto compartilhado.

P2 Remover credenciais fixas do Compose e exigir segredos injetados; separar perfil dev/prod e validar startup.

P3 Eliminar concatenação insegura: preferir textContent/DOM APIs e sanitização allowlist onde HTML for indispensável.

P4 Criar API persistente com ownership, auditoria, rate limit e testes de autorização; só então executar testes E2E reais.

ISSUES PARA O GITHUB

Blocos prontos para copiar e colar:

Severidade	Arquivo:linha	Descrição
Alta	docker-compose.yml:11-13	Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco). Se o Compose for exposto ou reutilizado fora de uma rede local isolada, a senha é previsível e reutilizável; não há validação que rejeite esses valores em produção.
Média	dist/index.html:12-15	O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape. Um valor como nome, nicho, produto, site ou status contendo HTML pode executar script no mesmo contexto quando renderizado. A exploração exige escrita no localStorage ou entrada pelo próprio fluxo local.
Média	dist/operacao.html:21,23	Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização. Uma decisão contendo marcação HTML pode executar script ao reabrir/renderizar a operação; a exploração é limitada ao contexto local da aplicação.
Alta	traficccagent/__main__.py:1-17; dist/index.html:1-15	Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático. Se publicado como sistema multiusuário, qualquer pessoa com acesso à URL poderá operar o painel; os papéis visuais não formam uma barreira no servidor.
Média	dist/index.html:12-15; dist/operacao.html:19-23	Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage. Usuários do mesmo perfil/origem podem ler, alterar, duplicar ou arquivar dados uns dos outros. Isso é uma lacuna de arquitetura do MVP, não um IDOR HTTP.

Recomendações priorizadas

P1 Definir autenticação, autorização server-side e modelo de tenant antes de transformar o mockup em produto compartilhado.

P2 Remover credenciais fixas do Compose e exigir segredos injetados; separar perfil dev/prod e validar startup.

P3 Eliminar concatenação insegura: preferir textContent/DOM APIs e sanitização allowlist onde HTML for indispensável.

P4 Criar API persistente com ownership, auditoria, rate limit e testes de autorização; só então executar testes E2E reais.

ISSUES PARA O GITHUB

Blocos prontos para copiar e colar:

Severidade	Arquivo:linha	Descrição
Alta	docker-compose.yml:11-13	Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco). Se o Compose for exposto ou reutilizado fora de uma rede local isolada, a senha é previsível e reutilizável; não há validação que rejeite esses valores em produção.
Média	dist/index.html:12-15	O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape. Um valor como nome, nicho, produto, site ou status contendo HTML pode executar script no mesmo contexto quando renderizado. A exploração exige escrita no localStorage ou entrada pelo próprio fluxo local.
Média	dist/operacao.html:21,23	Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização. Uma decisão contendo marcação HTML pode executar script ao reabrir/renderizar a operação; a exploração é limitada ao contexto local da aplicação.
Alta	traficccagent/__main__.py:1-17; dist/index.html:1-15	Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático. Se publicado como sistema multiusuário, qualquer pessoa com acesso à URL poderá operar o painel; os papéis visuais não formam uma barreira no servidor.
Média	dist/index.html:12-15; dist/operacao.html:19-23	Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage. Usuários do mesmo perfil/origem podem ler, alterar, duplicar ou arquivar dados uns dos outros. Isso é uma lacuna de arquitetura do MVP, não um IDOR HTTP.

Recomendações priorizadas

P1 Definir autenticação, autorização server-side e modelo de tenant antes de transformar o mockup em produto compartilhado.

P2 Remover credenciais fixas do Compose e exigir segredos injetados; separar perfil dev/prod e validar startup.

P3 Eliminar concatenação insegura: preferir textContent/DOM APIs e sanitização allowlist onde HTML for indispensável.

P4 Criar API persistente com ownership, auditoria, rate limit e testes de autorização; só então executar testes E2E reais.

ISSUES PARA O GITHUB

Blocos prontos para copiar e colar:

Severidade	Arquivo:linha	Descrição
Alta	docker-compose.yml:11-13	Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco). Se o Compose for exposto ou reutilizado fora de uma rede local isolada, a senha é previsível e reutilizável; não há validação que rejeite esses valores em produção.
Média	dist/index.html:12-15	O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape. Um valor como nome, nicho, produto, site ou status contendo HTML pode executar script no mesmo contexto quando renderizado. A exploração exige escrita no localStorage ou entrada pelo próprio fluxo local.
Média	dist/operacao.html:21,23	Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização. Uma decisão contendo marcação HTML pode executar script ao reabrir/renderizar a operação; a exploração é limitada ao contexto local da aplicação.
Alta	traficccagent/__main__.py:1-17; dist/index.html:1-15	Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático. Se publicado como sistema multiusuário, qualquer pessoa com acesso à URL poderá operar o painel; os papéis visuais não formam uma barreira no servidor.
Média	dist/index.html:12-15; dist/operacao.html:19-23	Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage. Usuários do mesmo perfil/origem podem ler, alterar, duplicar ou arquivar dados uns dos outros. Isso é uma lacuna de arquitetura do MVP, não um IDOR HTTP.

Recomendações priorizadas

P1 Definir autenticação, autorização server-side e modelo de tenant antes de transformar o mockup em produto compartilhado.

P2 Remover credenciais fixas do Compose e exigir segredos injetados; separar perfil dev/prod e validar startup.

P3 Eliminar concatenação insegura: preferir textContent/DOM APIs e sanitização allowlist onde HTML for indispensável.

P4 Criar API persistente com ownership, auditoria, rate limit e testes de autorização; só então executar testes E2E reais.

ISSUES PARA O GITHUB

Blocos prontos para copiar e colar:

Severidade	Arquivo:linha	Descrição
Alta	docker-compose.yml:11-13	Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco). Se o Compose for exposto ou reutilizado fora de uma rede local isolada, a senha é previsível e reutilizável; não há validação que rejeite esses valores em produção.
Média	dist/index.html:12-15	O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape. Um valor como nome, nicho, produto, site ou status contendo HTML pode executar script no mesmo contexto quando renderizado. A exploração exige escrita no localStorage ou entrada pelo próprio fluxo local.
Média	dist/operacao.html:21,23	Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização. Uma decisão contendo marcação HTML pode executar script ao reabrir/renderizar a operação; a exploração é limitada ao contexto local da aplicação.
Alta	traficccagent/__main__.py:1-17; dist/index.html:1-15	Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático. Se publicado como sistema multiusuário, qualquer pessoa com acesso à URL poderá operar o painel; os papéis visuais não formam uma barreira no servidor.
Média	dist/index.html:12-15; dist/operacao.html:19-23	Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage. Usuários do mesmo perfil/origem podem ler, alterar, duplicar ou arquivar dados uns dos outros. Isso é uma lacuna de arquitetura do MVP, não um IDOR HTTP.

Recomendações priorizadas

P1 Definir autenticação, autorização server-side e modelo de tenant antes de transformar o mockup em produto compartilhado.

P2 Remover credenciais fixas do Compose e exigir segredos injetados; separar perfil dev/prod e validar startup.

P3 Eliminar concatenação insegura: preferir textContent/DOM APIs e sanitização allowlist onde HTML for indispensável.

P4 Criar API persistente com ownership, auditoria, rate limit e testes de autorização; só então executar testes E2E reais.

ISSUES PARA O GITHUB

Blocos prontos para copiar e colar:

--- ISSUE 1 ---

Título: [Segurança] Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco)

Labels sugeridas: security + alta

Descrição e exploração: Credenciais PostgreSQL de desenvolvimento estão fixas no Compose (usuário, senha e banco). Se o Compose for exposto ou reutilizado fora de uma rede local isolada, a senha é previsível e reutilizável; não há validação que rejeite esses valores em produção.

Evidência: docker-compose.yml:11-13

Impacto: risco conforme a condição descrita.

Sugestão de correção: remover defaults, implementar auth/tenant server-side e usar textContent, escape ou sanitização allowlist.

Critérios de aceite:

- [] Teste automatizado cobre o caso.
- [] Nenhum segredo/default inseguro em produção.
- [] Operação autorizada no servidor e vinculada ao tenant.
- [] Entrada hostil não executa HTML/JS.
- [] Evidência registrada.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

Título: [Segurança] O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape

Labels sugeridas: security + média

Descrição e exploração: O dashboard grava dados controlados pelo operador em localStorage e os concatena em innerHTML sem escape. Um valor como nome, nicho, produto, site ou status contendo HTML pode executar script no mesmo contexto quando renderizado. A exploração exige escrita no localStorage ou entrada pelo próprio fluxo local.

Evidência: dist/index.html:12-15

Impacto: risco conforme a condição descrita.

Sugestão de correção: remover defaults, implementar auth/tenant server-side e usar textContent, escape ou sanitização allowlist.

Critérios de aceite:

- [] Teste automatizado cobre o caso.
- [] Nenhum segredo/default inseguro em produção.
- [] Operação autorizada no servidor e vinculada ao tenant.
- [] Entrada hostil não executa HTML/JS.
- [] Evidência registrada.

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

Título: [Segurança] Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização

Labels sugeridas: security + média

Descrição e exploração: Eventos de decisão são coletados via prompt, persistidos em localStorage e renderizados em innerHTML sem sanitização. Uma decisão contendo marcação HTML pode executar script ao reabrir/renderizar a operação; a exploração é limitada ao contexto local da aplicação.

Evidência: dist/operacao.html:21,23

Impacto: risco conforme a condição descrita.

Sugestão de correção: remover defaults, implementar auth/tenant server-side e usar textContent, escape ou sanitização allowlist.

Critérios de aceite:

- ☐ Teste automatizado cobre o caso.
 - ☐ Nenhum segredo/default inseguro em produção.
 - ☐ Operação autorizada no servidor e vinculada ao tenant.
 - ☐ Entrada hostil não executa HTML/JS.
 - ☐ Evidência registrada.
- FIM ISSUE 3 ---

--- ISSUE 4 ---

Título: [Segurança] Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático

Labels sugeridas: security + alta

Descrição e exploração: Não existe autenticação ou autorização no produto executável: o backend é apenas um smoke test e o painel é HTML estático. Se publicado como sistema multiusuário, qualquer pessoa com acesso à URL poderá operar o painel; os papéis visuais não formam uma barreira no servidor.

Evidência: trafficagent/__main__.py:1-17; dist/index.html:1-15

Impacto: risco conforme a condição descrita.

Sugestão de correção: remover defaults, implementar auth/tenant server-side e usar textContent, escape ou sanitização allowlist.

Critérios de aceite:

- ☐ Teste automatizado cobre o caso.
 - ☐ Nenhum segredo/default inseguro em produção.
 - ☐ Operação autorizada no servidor e vinculada ao tenant.
 - ☐ Entrada hostil não executa HTML/JS.
 - ☐ Evidência registrada.
- FIM ISSUE 4 ---

--- ISSUE 5 ---

Título: [Segurança] Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage

Labels sugeridas: security + média

Descrição e exploração: Não existe isolamento por usuário, organização ou tenant: o estado operacional é global ao perfil do navegador via localStorage. Usuários do mesmo perfil/origem podem ler, alterar, duplicar ou arquivar dados uns dos outros. Isso é uma lacuna de arquitetura do MVP, não um IDOR HTTP.

Evidência: dist/index.html:12-15; dist/operacao.html:19-23

Impacto: risco conforme a condição descrita.

Sugestão de correção: remover defaults, implementar auth/tenant server-side e usar textContent, escape ou sanitização allowlist.

Critérios de aceite:

- ☐ Teste automatizado cobre o caso.
 - ☐ Nenhum segredo/default inseguro em produção.
 - ☐ Operação autorizada no servidor e vinculada ao tenant.
 - ☐ Entrada hostil não executa HTML/JS.
 - ☐ Evidência registrada.
- FIM ISSUE 5 ---